

IndieCrowdfund — Transaction Monitoring (TM) Controls

Date: March 13, 2026 **Platform:** IndieCrowdfund (indiecrowdfund.com) **Payment Processor:** Stripe (Stripe Connect Express)

1. Overview

IndieCrowdfund employs a comprehensive, multi-layered transaction monitoring program to detect and prevent terrorist financing, money laundering, fraud, and other financial crimes. Our controls combine automated systems (AI-powered fraud detection, bot blocking, rate limiting), third-party screening (Stripe Radar, Stripe Connect KYC/OFAC), and manual review processes (admin campaign review, audit logging). This document details each layer.

2. AI-Powered Fraud Detection & Content Moderation

IndieCrowdfund integrates AI-powered (Claude by Anthropic) fraud analysis and content moderation directly into the campaign review pipeline.

2A. Fraud Analysis (`analyzeFraud`)

Every project submission can be analyzed for fraud indicators using our AI system. The analysis produces:

- **Fraud Score:** 0–100 scale (higher = more likely fraud)
- **Risk Factors:** Itemized list with severity ratings (low / medium / high)
- **Recommendation:** `approve` , `manual_review` , Or `reject`
- **Explanation:** Detailed assessment narrative

Fraud indicators checked:

1. Unrealistic promises or guarantees
2. Claims of "guaranteed returns" or "no risk"
3. Vague or copied descriptions
4. Unrealistic timelines
5. Goal amounts that don't match project scope
6. New creator with ambitious claims and no track record
7. Rewards that seem too good to be true
8. Missing or vague risk disclosures

9. Cryptocurrency/NFT projects with investment language
10. Impersonation of known brands or creators

Fail-safe behavior: If the AI analysis encounters an error, the project is automatically flagged for manual review with a fraud score of 50 (medium risk). The system fails closed — never auto-approving when analysis fails.

2B. Content Moderation (`moderateContent`)

A separate AI moderation pass evaluates project content against platform policies:

- **Risk Level:** `low`, `medium`, `high`, or `critical`
- **Policy Flags:** Specific violations identified
- **Suggested Action:** `approve`, `review`, or `reject`
- **Confidence Score:** 0.0–1.0

Policies enforced:

1. No illegal products or services
2. No weapons, drugs, or dangerous items
3. No adult content or explicit material (unless properly declared)
4. No hate speech or discrimination
5. No misleading claims or false advertising
6. No pyramid schemes or investment scams
7. No unauthorized reselling of existing products
8. AI-generated content must be disclosed
9. No charity projects (platform is for creative/product projects)
10. Must have tangible deliverables

Fail-safe behavior: On moderation errors, projects are flagged for manual review with `riskLevel: "medium"` and `suggestedAction: "review"`.

2C. Safety Review (`safetyReview`)

A third AI pass checks project readiness before going live:

- Clear project goals and deliverables
- Realistic timelines
- Adequate risk disclosure
- No harmful or dangerous elements
- Professional presentation quality

2D. Content Risk Flags (Database-Level)

Projects carry persistent risk flags in the database:

- `hasAdultContent` — Declares adult/explicit content

- `hasRiskyContent` — Flagged as potentially risky by review
- `promoContentSfw` — Confirms promotional materials are safe for work

These flags determine payment processor eligibility (e.g., NSFW projects cannot use Stripe) and trigger enhanced review.

3. Bot Detection & Suspicious Activity Tracking

Automated Bot Blocker System

A real-time bot detection system monitors all incoming requests:

- **Threshold:** 3 suspicious violations within 1-hour window triggers automatic IP block
- **Block Duration:** 24 hours per block
- **Escalation:** Repeat offenders accumulate violation counts
- **Firewall Integration:** Blocked IPs are written to `/tmp/botblock-pending` for near-instant iptables firewall rules

Detection methods:

- **Name gibberish detection:** Shannon entropy analysis identifies randomly generated names
- **Pattern matching:** Detects common bot names (test, admin, qwerty, etc.)
- **Vowel ratio analysis:** Flags statistically unlikely character distributions
- **Repeated pattern detection:** Catches copy-paste bot registrations
- **Server Action ID validation:** Detects spoofed Next.js server action requests

Database tracking:

- `BlockedIP` — Currently blocked IPs with violation count, expiry, user agent, and path
- `SuspiciousActivity` — Full log of every suspicious request (IP, reason, path, user agent, action ID, timestamp)

Cleanup: Automated 7-day retention with cron-based cleanup of expired blocks and logs.

reCAPTCHA Integration

Google reCAPTCHA v2 protects critical entry points:

- User registration forms
- Login pages
- Password reset requests

The system fails closed — if reCAPTCHA verification encounters an error, the request is denied.

4. Rate Limiting & Account Lockout

Authentication Rate Limiting

Multi-layer rate limiting protects all authentication flows:

Flow	Max Attempts	Window	Lockout Duration
Login (per IP)	5	5 minutes	5 minutes
Login (per account)	5	5 minutes	5 minutes, escalates to 1 hour after 3 lockouts
Registration (per IP)	5	1 hour	1 hour
Password Reset (per IP)	3	15 minutes	15 minutes
Password Reset (per account)	3	15 minutes	15 minutes

Lockout escalation: After 3 lockout events on the same account, the lockout duration extends to 1 hour to prevent persistent brute-force attacks.

Backend: Upstash Redis for multi-instance consistency with automatic in-memory fallback if Redis is unavailable.

Global API Rate Limiting

All API endpoints are rate-limited with configurable thresholds stored in the platform settings database. Rate limit configuration is manageable by super admins.

5. Payment Transaction Monitoring

5A. Stripe Webhook Monitoring

Real-time webhook handlers monitor all Stripe payment events:

Event	Monitoring Action
<code>payment_intent.succeeded</code>	Verify pledge status, update stats atomically, send confirmation
<code>payment_intent.payment_failed</code>	Log failure reason, schedule retry, notify backer
<code>setup_intent.succeeded</code>	Save payment method, update pledge, check funding status
<code>account.updated</code>	Monitor creator Stripe Connect onboarding status changes
<code>checkout.session.completed</code>	Process marketplace purchases

Anti-duplication controls:

- **Idempotency checks:** Every webhook event ID is recorded in `ProcessedWebhookEvent` table — duplicates are rejected
- **Atomic stat updates:** Uses `confirmationEmailSent` flag as a mutex to prevent double-counting between webhook and API endpoints
- **Status verification:** Checks pledge status before processing — already-completed pledges are skipped

5B. Payment Failure Tracking & Retry

Failed payments are tracked and retried systematically:

- **Max retries:** 3 attempts per pledge
- **Retry interval:** 3 days between attempts
- **Idempotency keys:** `charge_pledge_{pledgeId}_v{retryCount}` prevents duplicate charges
- **Pre-charge validation:** Checks for existing `PaymentIntents` before creating new ones
- **Failure logging:** `lastFailureReason` stored on every pledge for pattern analysis

After 3 failed attempts: - Pledge status set to `FAILED` - Backer notified via email - `nextRetryAt` cleared (no further attempts)

5C. Escrow Model — Pre-Disbursement Hold

Funds are not immediately disbursed. The escrow model provides a monitoring window:

1. **Before funding goal:** Payment methods saved via `SetupIntent` — no charge occurs
2. **Campaign reaches goal:** Cron job processes pending pledges in batches (max 100 per run)
3. **Payment method sync:** Failsafe syncs payment methods from Stripe before charging, in case webhooks were missed
4. **Transfer routing:** Funds routed to verified US-based creator accounts via `transfer_data.destination`

If a campaign fails or is cancelled, saved payment methods are never charged.

6. Stripe's Third-Party Controls (Outsourced)

IndieCrowdfund relies on Stripe for the following automated, outsourced TM controls:

Stripe Radar

- Real-time machine learning fraud scoring on every transaction
- Behavioral signals, device fingerprinting, and network analysis
- Automatic blocking of high-risk transactions

Stripe Connect KYC/AML

- Identity verification for all creator connected accounts (US-only)
- SSN/Tax ID verification
- US bank account verification
- OFAC SDN list screening (initial and ongoing)
- UN, EU, UK HM Treasury, and Australian sanctions list screening

Card-Issuer Country Blocking

- Stripe automatically declines cards issued in comprehensively sanctioned countries (Cuba, Iran, North Korea, Syria, Crimea)

Ongoing Monitoring

- Continuous monitoring of connected accounts for sanctions status changes
- Automatic alerts when account risk profiles change

7. Admin Enforcement & Account Controls

User Account Actions (Super Admin Only)

Action	Effect
Lock Account	Prevents login, records reason and admin who locked
Unlock Account	Restores access
Ban User	Locks account + adds IP to blocklist + deletes all sessions
Unban User	Unlocks account + optionally removes IP block

IP Blocklist System

Three tiers of IP blocking:

1. **Automated (Bot Blocker):** 24-hour blocks for suspicious activity — `BlockedIP` table
2. **Admin (User Bans):** Permanent blocks tied to banned users — `IPBlocklist` table
3. **Email/Domain Blocklist:** Blocks by email, domain, IP pattern, or regex — `EmailBlocklist` table

Campaign Enforcement

- Admin can reject campaigns at review, request changes, or revoke approval at any stage
- Projects flagged by AI with `riskLevel: "high"` or `"critical"` require manual review
- Automatic disqualification for creators with 3+ unfulfilled campaigns or any campaign 1yr+ past delivery

8. Comprehensive Audit Logging

All sensitive actions are logged with full attribution:

Logged Actions

- USER_ROLE_CHANGE, USER_BAN, USER_UNBAN, USER_LOCK, USER_UNLOCK, USER_DELETE
- USER_PASSWORD_SET, USER_PASSWORD_RESET, USER_EMAIL_CHANGE, USER_EMAIL_VERIFY
- PROJECT_APPROVE, PROJECT_REJECT, PROJECT_DEACTIVATE, PROJECT_REACTIVATE, PROJECT_MAKE_LIVE
- PAYOUT_CREATE, PAYOUT_PROCESS, PAYOUT_COMPLETE, PAYOUT_FAIL, PAYOUT_CANCEL
- BANK_ACCOUNT_VIEW (sensitive data access)
- IP_BLOCK, IP_UNBLOCK
- SETTINGS_CHANGE, ENCRYPTION_KEY_CHANGE, API_KEY_CHANGE

Audit Entry Structure

Each log entry contains: - **Action type** — What happened - **Actor ID & email** — Who performed it - **Target ID & type** — What was affected - **Details** — Additional context and metadata - **Changes** — Before/after values (sensitive fields are automatically masked) - **Timestamp** — When it occurred

Sensitive Field Masking

The audit system automatically masks sensitive values including: Stripe API keys, webhook secrets, SMTP passwords, SendGrid/Mailgun keys, encryption keys, and all payment processor secrets.

9. Automated Cron Job Monitoring

Scheduled jobs provide continuous transaction monitoring:

Cron Job	Purpose	Frequency
process-funded-campaigns	Charge pending pledges when campaigns fund	Every 5 minutes
payment-retries	Retry failed payment charges	Hourly
process-failed-campaigns	Handle expired/failed campaigns	Daily
cleanup-pledges	Clean up orphaned pledge records	Daily

Cron Job	Purpose	Frequency
email-queue	Process outbound email notifications	Every minute
email-retries	Retry failed email deliveries	Every 5 minutes

All cron jobs are protected by `CRON_SECRET` authentication and managed via the admin dashboard.

10. Circuit Breaker Protection

External service failures are monitored and managed via circuit breakers:

Service	Failure Threshold	Cooldown
Stripe	5 failures	30 seconds
SendGrid	3 failures	60 seconds
Mailgun	3 failures	60 seconds
R2 Storage	5 failures	15 seconds

States: CLOSED (normal) → OPEN (fast-fail when down) → HALF_OPEN (testing recovery)

This prevents cascading failures when external APIs experience outages and ensures the platform degrades gracefully.

11. Summary: Is TM Outsourced to a Third Party?

Partially. Our transaction monitoring is a hybrid model:

Layer	Handled By	Type
Sanctions screening (OFAC, UN, EU, UK, AU)	Stripe (third party)	Automated
Card fraud scoring (Radar)	Stripe (third party)	Automated
Card-issuer country blocking	Stripe (third party)	Automated
KYC/identity verification	Stripe (third party)	Automated
AI fraud analysis & content moderation	IndieCrowdfund (in-house, powered by Anthropic Claude)	Automated
Bot detection & IP blocking	IndieCrowdfund (in-house)	Automated
Rate limiting & account lockout	IndieCrowdfund (in-house)	Automated

Layer	Handled By	Type
reCAPTCHA bot protection	Google (third party)	Automated
Campaign admin review & approval	IndieCrowdfund (in-house)	Manual
Creator due diligence & cross-platform audit	IndieCrowdfund (in-house)	Manual
Account locking, banning, IP blocking	IndieCrowdfund (in-house)	Manual
Audit logging & compliance documentation	IndieCrowdfund (in-house)	Automated

12. Contact

For compliance inquiries: trust@indiecrowdfund.com For general support: support@indiecrowdfund.com Website: <https://www.indiecrowdfund.com>